Cybersecurity Lab: HSTS Case Study

Lab Objective

The aim of this lab was to assess the impact of HTTP Strict Transport Security (HSTS) on web security by testing and manipulating site responses using Burp Suite. Two scenarios were examined:

- Case A: Website without HSTS.
- Case B: Website with HSTS enabled.

Made with GAMMA

Case A: Website Without HSTS

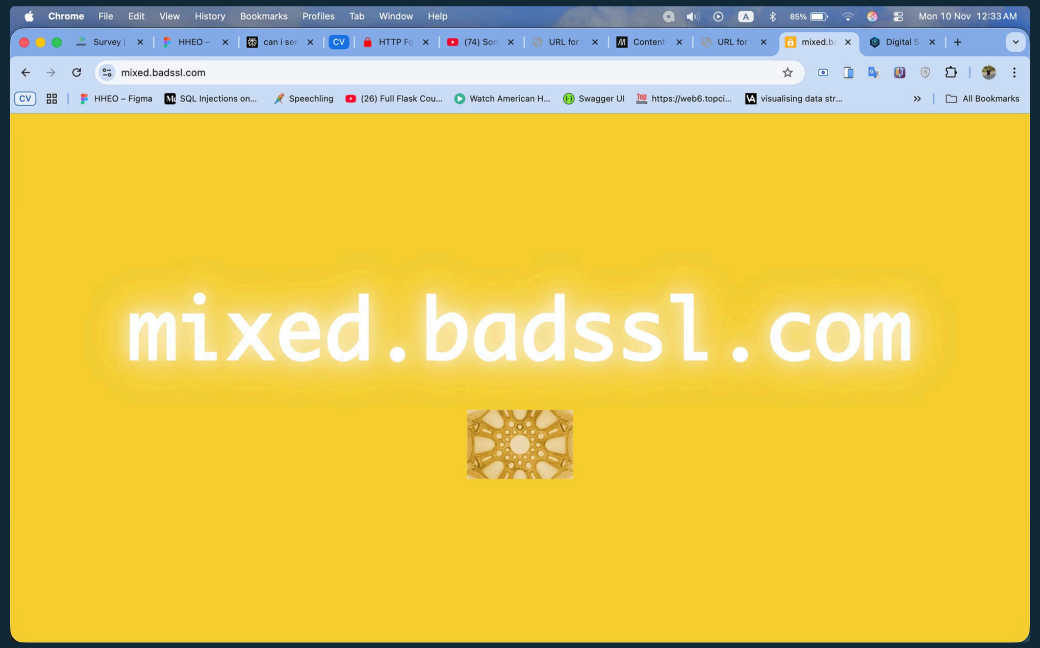
Test Target:

https://mixed.badssl.com/

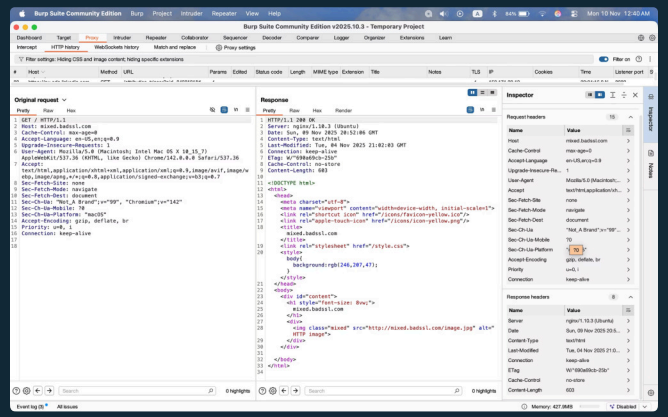
- Using Burp Suite, requests and responses on mixed.badssl.com were intercepted and modified.
- Screenshots show altering content on the site and successful manipulation in browser via HTTP and HTTPS.
- The absence of the **Strict-Transport-Security** header allowed direct changes to data and content for users, evidencing a vulnerability.
- Browsers would not enforce HTTPS for future visits, leaving users potentially exposed to SSLStrip and downgrade attacks.

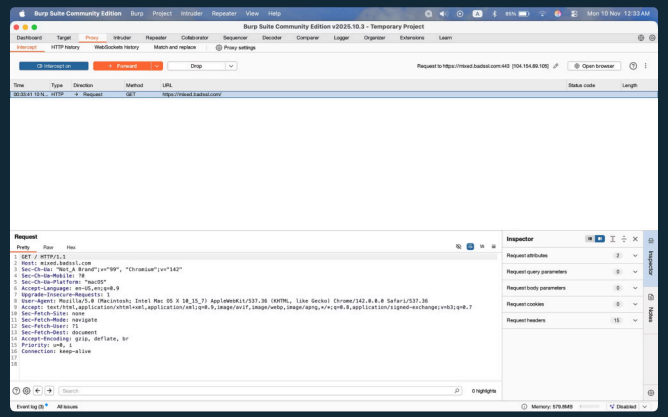
Lab Screenshots: Include images showing the request/response in Burp, browser rendered altered page, and evidence of missing HSTS header.

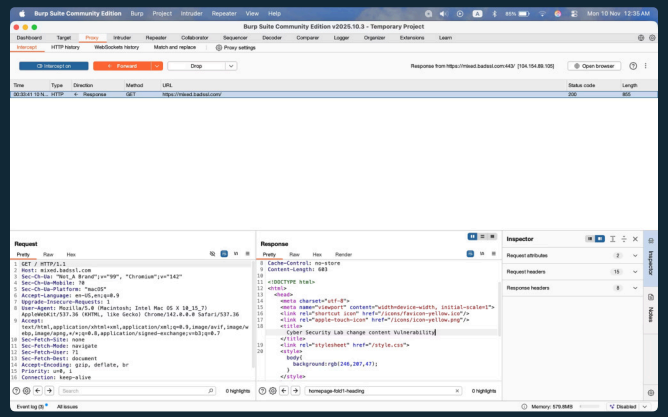
Made with GAMMA



Made with GAMMA







Made with GAMMA

Case B: Website With HSTS

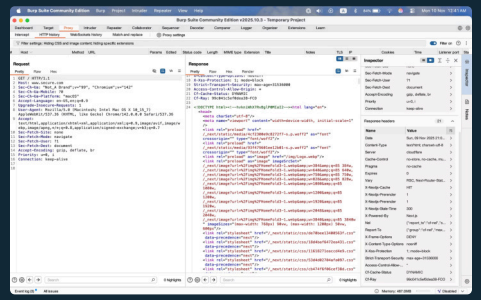
Test Target:

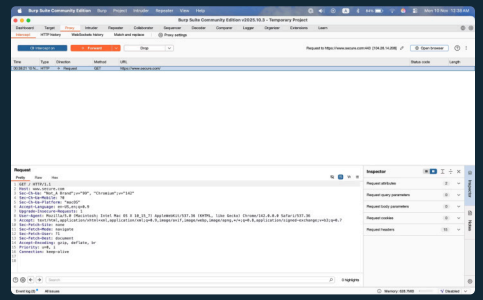
https://www.secure.com/

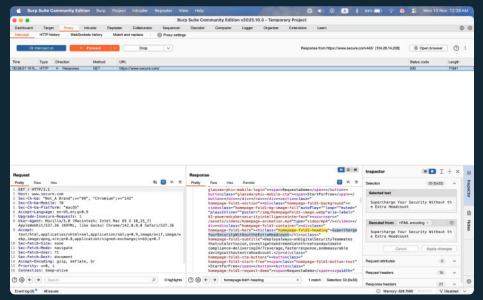
- Secure.com uses HSTS (**Strict-Transport-Security: max-age=31536000**).
- Intercepted and attempted modification of content and redirects in Burp Suite.
- Screenshots document both the manipulation attempts and the browser resistance to any HTTP downgrade/redirection.
- The browser immediately enforced HTTPS, even when redirects were changed in Burp, demonstrating the effectiveness of HSTS in preventing SSLStrip and downgrade attacks.

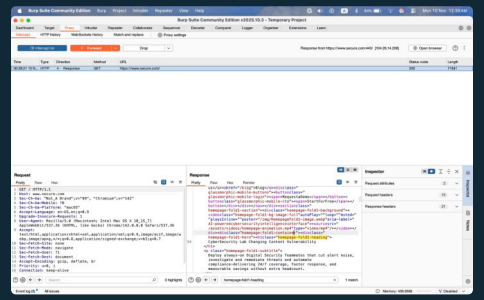
Lab Screenshots: Include visuals showing the request/response with the HSTS header, manipulation attempts, and proof the browser remains on HTTPS.

Made with GAMMA

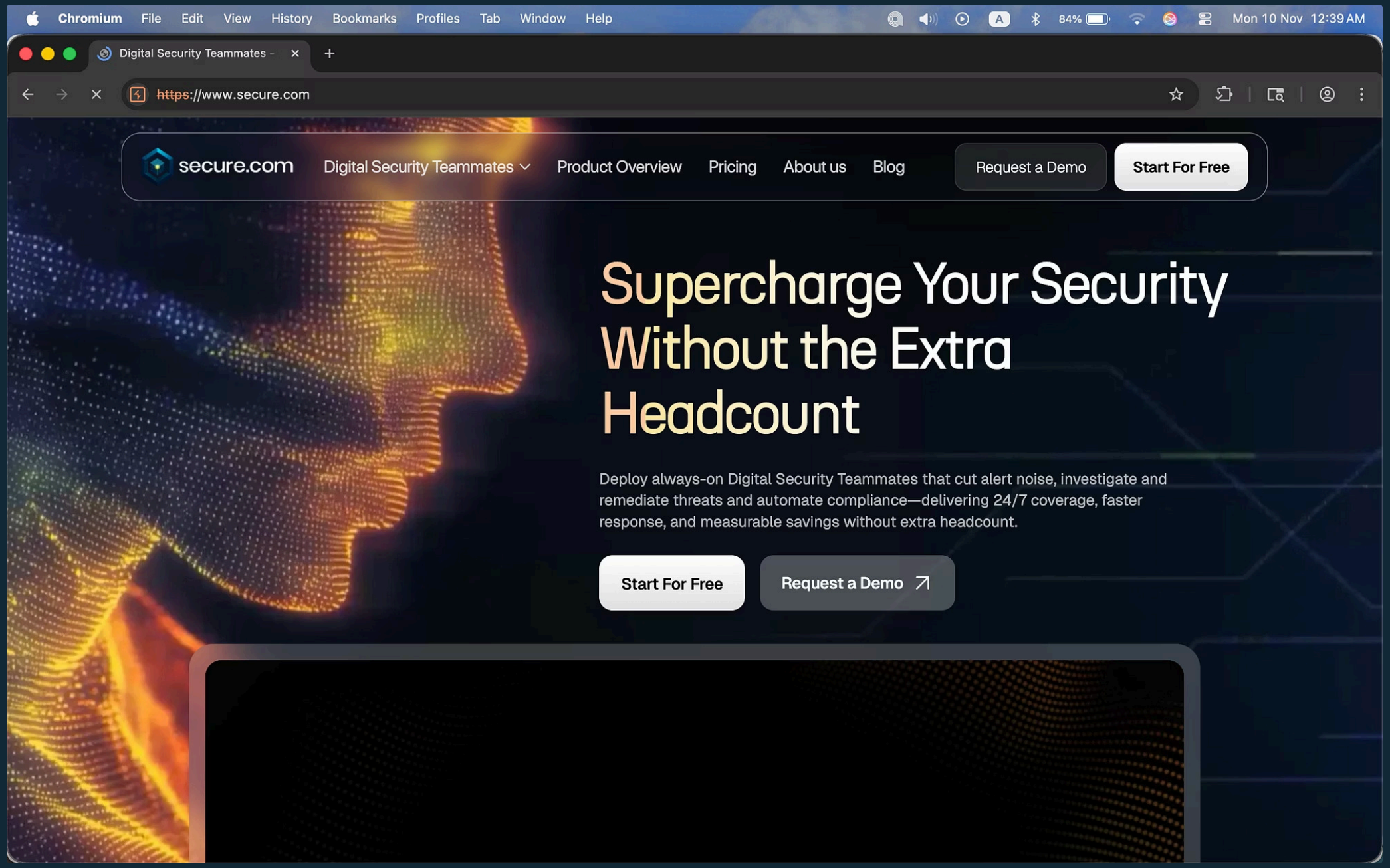








Made with GAMMA



Made with GAMMA

Key Observations

HSTS Protection

HSTS prevents modern browsers from accepting HTTP connections to protected domains, securing user data.

Vulnerability Without HSTS

Without HSTS, sites are exposed to MITM attacks, forced downgrades, and content modification.

Critical Security Role

Hardened responses were only possible for domains with HSTS—proving its crucial role in web security.

Made with GAMMA

Conclusion

These tests conclusively show that enabling HSTS is a fundamental part of web server security. The visual differences and browser responses in each case highlight the risk of omitting HSTS and offer tangible evidence supporting its adoption.

Key Takeaway: HSTS is essential for protecting users from downgrade attacks and man-in-the-middle threats. Organizations must implement HSTS headers on all HTTPS-enabled domains to ensure maximum security.

Made with GAMMA